

Хранение секретов вне Git: архитектура и восстановление

1. Принцип

Секреты (пароли, токены, API-ключи) **никогда** не хранятся в отслеживаемых Git файлах и не попадают на GitHub. Они лежат в **едином хранилище вне репозитория**, а конфигурации ссылаются на них по пути.

Единое хранилище:

%USERPROFILE%\ .ais-secrets\

(C:\Users\vchaga\ .ais-secrets)

└─ opencode\

├─ jira_token.txt Jira PAT (MCP atlassian)

├─ confluence_password.txt пароль Confluence (Basic, MCP atlassian)

└─ google_api_key.txt ключ провайдера Google

Каталог расположен **вне** C:\AIS\AI\Prod , поэтому физически не может попасть в репозиторий C:\AIS\AI\Prod даже при ошибке в .gitignore .

2. Топология: кто откуда берёт секреты

Секрет	Файл хранилища	Потребитель	Способ подключения
Jira PAT	~/.ais-secrets/opencode/jira_token.txt	MCP atlassian (Jira)	{file:~/.ais-secrets/opencode/jira_token.txt} в обоих opencode.jsonc

Пароль Confluence	<code>~/.ais-secrets/opencode/confluence_password.txt</code>	MCP <code>atlassian</code> (Confluence Basic)	<code>{file:~/.ais-secrets/opencode/confluence_password.txt}</code>
Google API-ключ	<code>~/.ais-secrets/opencode/google_api_key.txt</code>	провайдер <code>google</code>	<code>{file:~/.ais-secrets/opencode/google_api_key.txt}</code>
Пароль/ логин EWS	<code>~/.config/ews-mcp/credentials.env</code>	MCP <code>ews</code>	штатный загрузчик EWS (<code>~/.config/ews-mcp/credentials.env</code>)
Секреты PS- модулей	<code>C:\AIS\AI\Prod\config\.local_secrets.json</code>	существующие PowerShell- модули проекта	<code>scripts\Read-SecretFromConfig.ps1</code>

Подстановка `{file:...}` в конфигурации OpenCode поддерживает относительные пути (от каталога конфига), абсолютные (начинаются с `/`, `~`) — см. документацию OpenCode, раздел Variables → Files.

3. Почему это не ломает работу системы

- 1. **Секреты не удалены** — они перенесены в `~/.ais-secrets` и остаются на диске.
- 2. **Конфиги ссылаются по пути** — при запуске OpenCode подставляет содержимое файла в поле. Для Jira/Confluence/Google работает так же, как раньше (проверено: Jira HTTP 200, Confluence HTTP 200).
- 3. **Файлы только на чтение для конфигов** — потеря/замена не портит сам конфиг, достаточно восстановить файл.
- 4. **Сервис «ПАРОЛЬ»** (C# WPF) показывает состояние секретов и умеет проверять их сетевую валидность, не печатая значения.

4. Смена и восстановление секретов (сервис «ПАРОЛЬ»)

Сервис реализован на **C# WPF** (не PowerShell): `scripts\SetupSecrets\` → `Setup-Secrets.exe`.

Запуск — командой проекта **ПАРОЛЬ** или напрямую:

Вкладка «OpenCode / MCP (вне Git)»

Поле	Файл хранилища
Jira PAT-токен	~/.ais-secrets/opencode/jira_token.txt
Confluence пароль	~/.ais-secrets/opencode/confluence_password.txt
Google API-ключ	~/.ais-secrets/opencode/google_api_key.txt

- Кнопка «Сохранить» пишет файлы **без BOM и без завершающего перевода строки** (именно так их читает подстановка {file:...}); каталог создаётся автоматически.
 - Кнопка «Проверить» выполняет реальные запросы: Jira /rest/api/2/myself , Confluence /rest/api/user/current , и показывает HTTP-код и результат.
 - После сохранения — **перезапуск OpenCode** (значения читаются при старте).
- На вкладках Sybase , VSS , Jira , OpenCode API , EWS сервис сохраняет значения в config\local_secrets.json (шифрование DPAPI, только текущий пользователь) и в ~/.config/ews-mcp/credentials.env .

Порядок смены любого секрета

1. Получить новое значение в источнике (Jira / Confluence / Google / EWS).
2. Открыть сервис (**ПАРОЛЬ**), ввести значение, «Сохранить».
3. **Перезапустить OpenCode.**
4. Нажать «Проверить».

Важно: **Jira работает по PAT-токену, а не по паролю.** Смена доменного пароля Jira не затрагивает — обновлять jira_token.txt нужно только при перевыпуске/отзыве токена. Пароль (confluence_password.txt) используется для Confluence (Basic) и, при совпадении учётной записи, для EWS (~/.config/ews-mcp/credentials.env → EWS_PASSWORD).

Если пароль/токен скомпрометирован

1. Сменить секрет в источнике (Jira/Confluence/Google/EWS).
2. Внести новое значение через сервис «ПАРОЛЬ» и сохранить.
3. Перезапустить OpenCode.
4. Нажать «Проверить».

5. Что было исправлено (инцидент 18.09.2026)

Проблема	Решение
Каталог <code>.config</code> — junction внутри репозитория; глобальный <code>opencode.jsonc</code> отслеживался Git	Секреты вынесены в <code>~/.ais-secrets</code> ; в конфиге — только подстановки <code>{file:...}</code>
Jira PAT, Google API-ключ, EWS-логин/пароль были закоммичены и опубликованы на GitHub	Секреты ротированы; файл <code>credentials.env</code> снят с отслеживания (<code>git rm --cached</code>)
API-ключи в <code>rules/pending-tasks.md</code>	Заменены ссылкой на <code>config\.local_secrets.json</code>
Хук <code>scripts\pre-commit.exe</code> даёт ложные срабатывания на <code>{file:...}</code>	Требуется доработка (проверка подстановок вместо значений)

6. Правила на будущее

- Секреты — только в `~/.ais-secrets` (OpenCode) или `config\.local_secrets.json` (PS-модули); в конфигах — ссылки `{file:...}`.
- Никогда не добавлять в Git то, что под каталогом `.config` содержит значения секретов.
- Новые сервисы — только C#/Python; **новые .ps1 не создавать** (антивирус, см. AGENTS.md).
- После любых правок секретов — сервис «ПАРОЛЬ» → «Проверить» и перезапуск OpenCode.
- При потере значений — восстановить из менеджера паролей и повторить проверку.